

DocuControl — OWASP-Sicherheitsbericht

Gerät: DocuControl (Pi5_Display, Belimed-Autoklavenbuch Uni Essen) **Prüfmethode:** Manuelles Review nach OWASP Top 10 (2021) — Quellcode-Review + Live-Endpunkt-Tests **Datum:** 21.–22.06.2026 **Geprüft durch:** Claude Code (Sonnet 4.6), im Auftrag von Thomas Glander

Zusammenfassung

Das DocuControl-Webinterface wurde nach den OWASP-Top-10-Kategorien geprüft. Es wurden 3 kritische, 4 mittelschwere/hohe und mehrere positive Befunde identifiziert. **Alle identifizierten Schwachstellen wurden noch am selben Tag behoben, auf dem Live-Gerät deployed und funktional verifiziert.**

Das Gerät ist ein LAN-only-Industriegerät ohne Internet-Exposition (Betrieb im Kliniknetz, physischer Standortschutz). Für diesen Einsatzkontext erreicht es nach den Fixes ein angemessenes Sicherheitsniveau.

1. Kritische Befunde (sofort behoben)

#	Befund	OWASP-Kategorie	Status
1	Hardcodierte Secrets (SECRET_KEY , Service-Passwort) im Quellcode/Git-Historie	A02 Cryptographic Failures / A05 Security Misconfiguration	✓ behoben
2	Kein Brute-Force-Schutz beim Service-Login	A07 Identification and Authentication Failures	✓ behoben
3	XSS-Lücke in escHtml() (fehlendes Escaping von Anführungszeichen)	A03 Injection (XSS)	✓ behoben

Fixes: - Secrets werden beim ersten Start zur Laufzeit generiert und außerhalb des Git-Repos in data/auth_secrets.json persistiert (Dateirechte chmod 600). - 5 Fehlversuche beim Service-Login führen zu einer 5-minütigen Sperre (in-memory Tracking). - escHtml() in dashboard.html und filemanager.html escaped jetzt zusätzlich einfache und doppelte Anführungszeichen — verhindert das Ausbrechen aus onclick -Attributen.

2. Weitere Befunde (heute ebenfalls behoben)

#	Befund	OWASP-Kategorie	Status
4	Broken Access Control: destruktive Endpunkte (Löschen) ohne Berechtigungsprüfung	A01 Broken Access Control	✓ behooben
5	Permissive CORS-Konfiguration (cors_allowed_origins="")	A05 Security Misconfiguration	✓ behooben
6	Fehlender CSRF-Schutz am Session-Cookie	A01 Broken Access Control	✓ behooben
7	Keine Transportverschlüsselung (nur HTTP)	A02 Cryptographic Failures	✓ behooben

Fixes: - **Access Control:** Alle 7 destruktiven API-Endpunkte (Protokoll-Löschung, Bulk-Delete, Capture-Löschung/Bulk-Delete, Storage-Delete, Pending-Charge-Discard) verlangen jetzt eine aktive Service-Anmeldung (`_require_service()` -Guard). Vorher konnte jeder im Netzwerk ohne Anmeldung Protokolle und Rohdaten löschen. - **CORS:** Wildcard entfernt — Socket.IO und Web-UI laufen immer auf demselben Host, Same-Origin-Default reicht aus, keine geräteindividuelle Allowlist-Pflege nötig. - **CSRF:** Session-Cookie trägt jetzt `SameSite=Lax`. - **HTTPS:** Zusätzlicher TLS-Listener auf Port 5443 mit selbstsigniertem Zertifikat (automatisch beim ersten Start erzeugt), läuft **parallel** zum bestehenden Port 5000. Die Kiosk-URL `http://localhost:5000` bleibt bewusst unverändert, damit der produktive Touchscreen-Kiosk nicht durch Zertifikatswarnungen gestört wird. Externer Zugriff per Browser ist nun zusätzlich über `https://<ip>` möglich (nftables-Weiterleitung 443→5443 ergänzt).

3. Bewusst nicht behobene Punkte (geringes Restrisiko)

Befund	Begründung
TCP/9100-Druckempfang ohne Authentifizierung	Das Maschinenprotokoll-Format (Druckerabgriff der Sterilisationsanlage) erlaubt keine Authentifizierungsschicht. Risiko durch reinen LAN-Betrieb (kein Internetzugang, segmentiertes Kliniknetz) stark gemindert.
Kein vollständiges Audit-Logging für jede Aktion	Nur ausgewählte sicherheitsrelevante Ereignisse (Login, Fehlversuche, Löschvorgänge) werden protokolliert, kein lückenloses Audit-Log aller API-Aufrufe. Aufwand/Nutzen für dieses Gerät aktuell nicht gerechtfertigt.

4. Positive Befunde

- **Keine SQL-Injection:** Alle Datenbankzugriffe nutzen durchgängig parametrisierte Queries.
- **Path-Traversal-Schutz:** Dateinamen für Capture-Downloads werden per Regex validiert (`^[A-Za-z0-9_\-\.\ ]+$`).
- **Aktuelle Abhängigkeiten:** Flask 3.1.3, Werkzeug 3.1.8 — keine bekannten CVEs zum Prüfzeitpunkt.

5. Verifikation (Live-Tests auf dem Gerät)

Test	Ergebnis
HTTP (Port 80→5000) erreichbar	✓ 200 OK
HTTPS (Port 443→5443, selbstsigniert) erreichbar	✓ 200 OK
DELETE-Endpunkt ohne Anmeldung	✓ 403 „Service-Anmeldung erforderlich“
DELETE-Endpunkt mit Anmeldung	✓ funktioniert (404 bei nicht existierender ID, sonst Löschung)
Login mit falschem Passwort 5×, danach 6. Versuch	✓ Sperre „Zu viele Fehlversuche. Bitte 299s warten.“
Session-Cookie-Attribute	✓ HttpOnly; SameSite=Lax

6. Fazit

Das DocuControl-Gerät bestand den OWASP-Top-10-Test nach Behebung aller gefundenen Schwachstellen für den vorgesehenen Einsatzkontext (LAN-only-Industriegerät im geschützten Kliniknetz). Bei einer hypothetischen Exposition gegenüber dem offenen Internet wären zusätzlich ein vertrauenswürdiges (nicht selbstsigniertes) TLS-Zertifikat und ein vollständigeres Audit-Logging empfehlenswert — für den aktuellen Betrieb sind diese beiden Punkte jedoch nicht kritisch.

Dieser Bericht wurde im Rahmen der laufenden Entwicklungsarbeit am DocuControl-Projekt erstellt und spiegelt den Stand vom 22.06.2026 wider.